

Xolvon Backend – Handover Documentation

Official handover entry point for the Xolvon backend (NestJS 12, strict ESM, Node.js 22+). This folder is the canonical, code-verified reference. The root `README.md` and `ARCHITECTURE.md` predate some hardening work; where they disagree with this folder, the documents here (and the code) win.

Document index

Document	Purpose
[`README.md`](README.md)	(this file) From-zero setup, environment variables, commands, migrations, PDF build
[`architecture.md`](architecture.md)	Module map, data layer (SQLite/D1), storage port, auth model, full data model
[`security.md`](security.md)	Security headers, input sanitization, consolidated controls, audit results, limitations
[`deployment-runbook.md`](deployment-runbook.md)	Staging → production deployment, migration apply/rollback, admin bootstrap, monitoring status
[`api-contract.md`](api-contract.md)	Canonical endpoint contract (auth/role per route)
[`decision-log.md`](decision-log.md)	Locked decisions (DL- <i>nnn</i>), conflicts, open items
[`production-operations.md`](production-operations.md)	Environment separation, admin bootstrap, rollback, observability boundary
[`qa-results.md`](qa-results.md)	Live-deployment verification status (currently BLOCKED – recorded honestly)

1. Prerequisites

- **Node.js** v22.0.0+ (NestJS 12 runs native ESM)
- **npm** v10+
- No Cloudflare account, database, or bucket is needed for local development.

2. From-zero local setup

2.1 Clone and install

```
```bash
git clone <repository-url>
cd Project-SaaS-Xolvon
npm install
```
```

`.npmrc` sets `legacy-peer-deps=true` (required by the `@nestjs/throttler` peer range, see DL-016); a clean `npm install` on a fresh clone must exit 0.

2.2 Create `.env`

```
```bash
cp .env.example .env
```
```

``.env`` is gitignored – never commit it. The local defaults in ``.env.example`` run fully offline: ``APP_ENV=local`, `DB_DRIVER=sqlite`, `STORAGE_DRIVER=local-test``.

You must supply only two values locally (names below; put real values in ``.env``, never in docs or Git):

- ``JWT_SECRET`` – any high-entropy string of at least 32 characters (e.g. generate one with ``openssl rand -hex 32``).
- ``ADMIN_BOOTSTRAP_EMAIL`` / ``ADMIN_BOOTSTRAP_PASSWORD`` – only needed when you run ``npm run seed:admin`` (section 5); not read by the HTTP server.

All other blank variables (``CLOUDFLARE_*``, ``R2_*``) are validated only when the matching driver is selected (``DB_DRIVER=d1`` / ``STORAGE_DRIVER=r2``) – see ``src/config/env.validation.ts``. The validator fails fast at bootstrap and never echoes values.

2.3 Build

```
```bash
npm run build
```
```

2.4 Apply database migrations (local SQLite)

> **Important:** the HTTP server does **not** auto-apply migrations at startup. ``src/main.ts`` never runs them; ``local.db`` starts empty. You must > apply migrations once before the first run.

```
```bash
Applies all pending files in src/database/migrations/ to ./local.db
npx ts-node src/database/migrate.ts
```
```

(``npm run seed:admin`` also applies pending migrations first, so seeding implicitly migrates.)

2.5 Run locally

```
```bash
npm run start:dev # watch mode
or
npm run start:prod # node dist/main (after npm run build)
```
```

The API listens on ``http://localhost:PORT/api`` (default ``PORT=3000``). Smoke test – the health route is ``GET /api`` (it returns ``Hello World!`` and is exempt from all throttling groups):

```
```bash
curl -i http://localhost:3000/api
curl -s http://localhost:3000/api/courses # public catalog, paginated
```
```

3. Environment variable reference

Names and purposes only – **no secret values belong in this repo, in Git, in logs, or in any document.** The three templates are ``.env.example`` (local,

17 names), ``.env.staging.example`` and ``.env.production.example`` (15 names each); ``CORS_ALLOWED_ORIGINS`` is present but blank in all three. One further name is read at runtime but is not in the example files (see the row marked `*runtime-optional*`).

| Variable | Purpose | Required |
|--|---|---|
| --- | --- | --- |
| <code>`APP_ENV`</code> | Runtime mode: <code>`local`</code> \ <code>`staging`</code> \ <code>`production`</code> . <code>`production`</code> enables HSTS in security headers. | Optional, defaults <code>`local`</code> |
| <code>`PORT`</code> | HTTP listen port (integer 1–65535). | Optional, defaults <code>`3000`</code> |
| <code>`DB_DRIVER`</code> | Persistence driver: <code>`sqlite`</code> (better-sqlite3 on <code>`local.db`</code>) \ <code>`d1`</code> (Cloudflare D1 REST adapter). | Optional, defaults <code>`sqlite`</code> |
| <code>`CLOUDFLARE_ACCOUNT_ID`</code> | Cloudflare account id for the D1 REST endpoint. | Required when <code>`DB_DRIVER=d1`</code> |
| <code>`CLOUDFLARE_D1_DATABASE_ID`</code> | D1 database id the REST adapter queries. | Required when <code>`DB_DRIVER=d1`</code> |
| <code>`CLOUDFLARE_API_TOKEN`</code> | Bearer token used per-query against the D1 REST API (never stored on the service instance). | Required when <code>`DB_DRIVER=d1`</code> |
| <code>`STORAGE_DRIVER`</code> | Object storage driver: <code>`local-test`</code> (in-process stub, <code>`http://local-storage.test`</code> URLs) \ <code>`r2`</code> (Cloudflare R2 via S3 presigning). | Optional, defaults <code>`local-test`</code> |
| <code>`R2_ENDPOINT`</code> | S3-compatible R2 endpoint (must be absolute <code>`https:`</code> URL). Its origin also feeds CSP source lists. | Required when <code>`STORAGE_DRIVER=r2`</code> |
| <code>`R2_BUCKET`</code> | R2 bucket name. | Required when <code>`STORAGE_DRIVER=r2`</code> |
| <code>`R2_ACCESS_KEY_ID`</code> | R2 access key id. | Required when <code>`STORAGE_DRIVER=r2`</code> |
| <code>`R2_SECRET_ACCESS_KEY`</code> | R2 secret access key. | Required when <code>`STORAGE_DRIVER=r2`</code> |
| <code>`JWT_SECRET`</code> | HS secret for signing/verifying access tokens (<code>`AuthGuard`</code>). | Always required (min 32 chars) |
| <code>`FRONTEND_URL`</code> | Primary allowed browser origin; CORS and request-integrity fallback when <code>`CORS_ALLOWED_ORIGINS`</code> is unset. | Always required (valid <code>`http(s)`</code> URL) |
| <code>`CORS_ALLOWED_ORIGINS`</code> | Comma-separated explicit whitelist of allowed origins (credentials mode; wildcards rejected). Also the request-integrity guard's allowed-origin set. Falls back to <code>`FRONTEND_URL`</code> , then <code>`http://localhost:3001`</code> . | Optional (blank in all three example files; set real origins per environment) |
| <code>`CSP_CONNECT_SRC`</code> | Comma/space-separated origins added to CSP <code>`connect-src`</code> / <code>`style-src`</code> / <code>`img-src`</code> / <code>`font-src`</code> . Malformed entries are dropped. Defaults to <code>`'self'`</code> . | Runtime-optional (not in the example files) |
| <code>`TRUST_PROXY_HOPS`</code> | Express <code>`trust proxy`</code> hop count for client-IP resolution behind the edge proxy. Unset/blank → <code>`false`</code> (fail closed: <code>`X-Forwarded-For`</code> cannot mint fresh throttle buckets); non-numeric → bootstrap aborts. | Staging/production templates set <code>`1`</code> . Optional (validated at bootstrap, not by <code>`env.validation.ts`</code>) |
| <code>`ADMIN_BOOTSTRAP_EMAIL`</code> | Email of the first admin account, consumed only by <code>`npm run seed:admin`</code> . | Required for <code>`seed:admin`</code> |
| <code>`ADMIN_BOOTSTRAP_PASSWORD`</code> | Password for the first admin account, consumed only by <code>`npm run seed:admin`</code> . | Required for <code>`seed:admin`</code> |

Cross-field validation lives in ``src/config/env.validation.ts`` and keys off ``DB_DRIVER``/``STORAGE_DRIVER`` – not off ``APP_ENV``.

4. Commands

| Command | What it does |
|---------------------------------|---|
| --- | --- |
| <code>`npm run test:esm`</code> | Unit/behavior suite (Jest with <code>`--experimental-vm-modules`</code> , |

```

via cross-env). Current baseline on this branch: 44 suites / 411 tests. |
| `npm run test:e2e` | End-to-end suite (`test/jest-e2e.json` harness with
overridden providers). Baseline: 107 tests. Runs fully against in-memory/local
SQLite – zero cloud credentials. |
`npm run build`	`nest build` → `dist/`.
`npm run lint`	`oxlint src/ test/`.
`npm run format`	Prettier over `src/` and `test/`.
`npm run test:cov`	Coverage report.
`npm run seed:admin`	Controlled first-admin bootstrap (section 5).
`npm run docs:pdf`	Regenerate committed PDFs (section 6).

```

Plain `npm test` (`jest` without the ESM flag) is **not** usable with this ESM-only codebase – always use `test:esm` / `test:e2e` (DL-008).

5. Adding and running a migration

Migrations are plain SQL files in `src/database/migrations/`, applied by `src/database/migrate.ts` in **filename sort order**, tracked in the `\_migrations` table (filename + SHA-256 content hash). Rules:

1. **Add** a new file `NNNN\_short\_description.sql` continuing the numeric prefix (next free number after `0007\_...`). Name only – content of applied files is immutable.
2. **Never edit an applied migration.** The runner compares the recorded hash and throws on drift (`"changed after it was applied"`), fail-closed. Fix forward with a new file.
3. Statements are split with a string/comment/trigger-aware splitter, so plain `;-`-separated DDL is safe.
4. **Run locally:** `npx ts-node src/database/migrate.ts` (applies to `./local.db` under the current working directory; prints `applied/skipped` counts). The HTTP server itself never runs it.
5. **Run against D1 (staging/production):**
`npx wrangler d1 migrations apply xolvon-staging --remote` – the database name and `migrations\_dir` are configured in `wrangler.jsonc`. See deployment-runbook.md for the full procedure and rollback policy (forward-only; compensating migration + deployment revert).
6. The `src/database/migrations/\_reference/` folder is a reference copy and is **not** applied (the runner only enumerates top-level `\*.sql` files).
7. Schema changes must be preceded by a `decision-log.md` entry (RULES §84); `SCHEMA.md` remains the schema source of truth.

6. Generating documentation PDFs

Per DL-019, official PDFs are produced with Playwright/Chromium and committed:

```

```bash
npm run docs:pdf
```

```

- Runs `scripts/docs-pdf.mjs`: renders the **four official handover docs** (`README.md`, `architecture.md`, `security.md`, `deployment-runbook.md`) to `docs/pdf/<name>.pdf` (A4, Chromium print pipeline), plus a combined `docs/pdf/xolvon-backend-full-documentation.pdf` in that order. It does **not** render the other `docs/\*.md` (`api-contract`, `decision-log`, `qa-results`, `production-operations`) – the deliverable set is pinned in the script.
- Requires the Chromium browser binary once per machine:
`npx playwright install chromium`.

- Output is deterministic for the same Markdown input; regenerate and secret-scan whenever these docs change.
- ``docs/Xolvon-API-Documentation.pdf`` (and its generator ``scripts/generate-api-pdf.py``) were a non-conforming, out-of-band pair (per DL-019) and were **deleted** at plan T9; they are not part of this workflow and no longer exist in the tree. See DL-026 in `[`decision-log.md`](decision-log.md)`.

7. House rules for contributors

- No secret or credential values in docs, tests, logs, Postman files, PDFs, or Git history – variable **names** only (DL-024, cleanup policy DL-025).
- No production deployment claims without real target + HTTPS domain + verification evidence (current status: blocked, see `[`qa-results.md`](qa-results.md)`).
- Endpoint or auth-model changes require updating `[`api-contract.md`](api-contract.md)` and a ``decision-log.md`` entry in the same change.